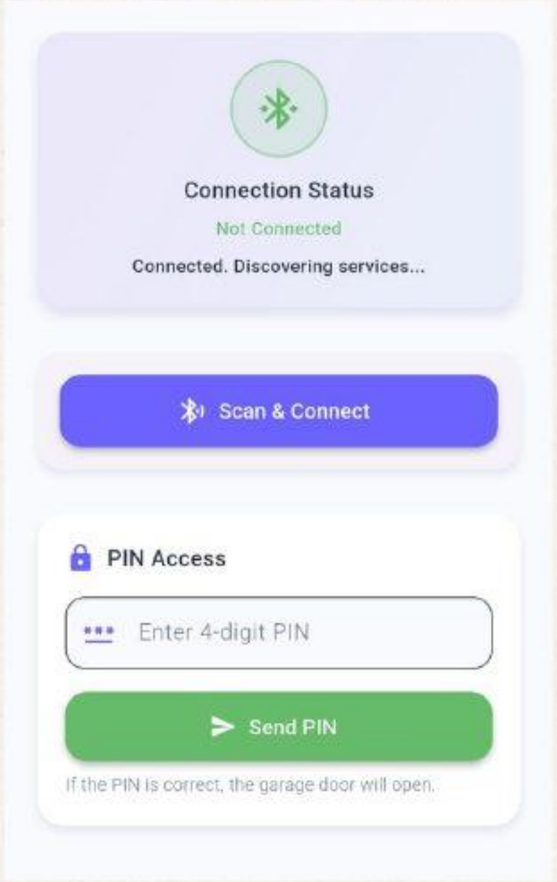
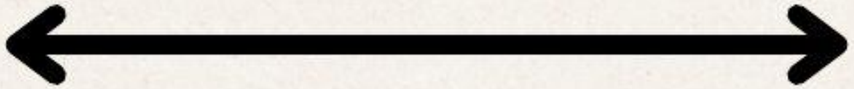
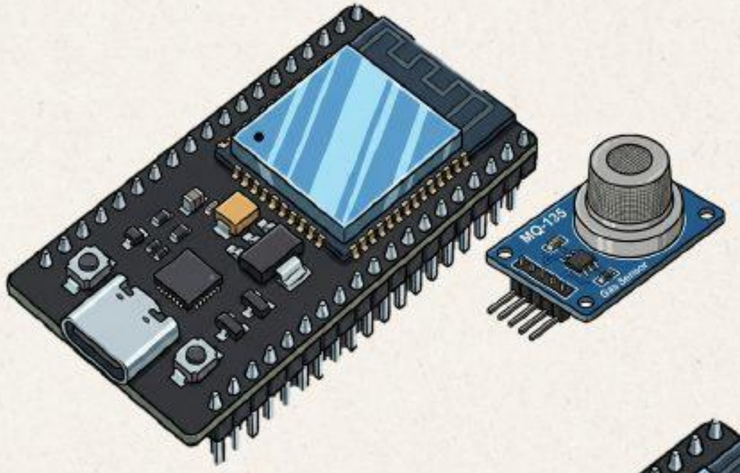
Problem

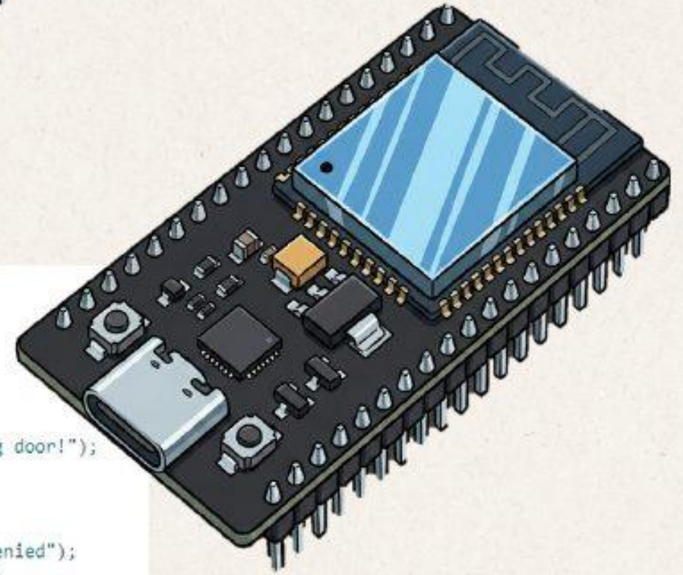
Flutter











```
  if (valueStd.length() == 0) return;

  Serial.print("Received PIN: ");
  Serial.println(valueStd.c_str());

  if (valueStd == CORRECT_PIN) {
    Serial.println("PIN correct → Opening door!");
    pTxCharacteristic->setValue("OK");
    pTxCharacteristic->notify();
  } else {
    Serial.println("WRONG PIN → Access denied");
    pTxCharacteristic->setValue("WRONG");
    pTxCharacteristic->notify();
  }
 }
};
```

Goal



All communications should be secure from end to end and resistant to replay attack

01	**Authentication**
02	**Integrity**
03	**Confidentiality**
04	**Accounting**
05	**Authorization**

Software and Hardware Used





mosquitto

Node-RED

docker

MQTT

InfluxDB

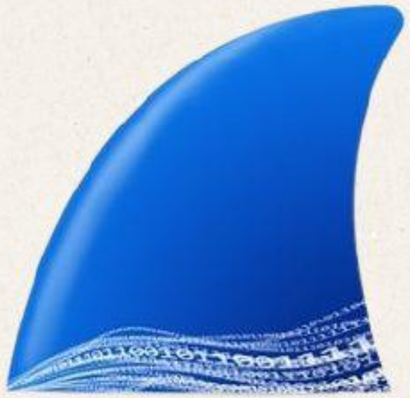


OpenSSL
Cryptography and SSL/TLS Toolkit

LE

CSP

Security Analysis
Tools used



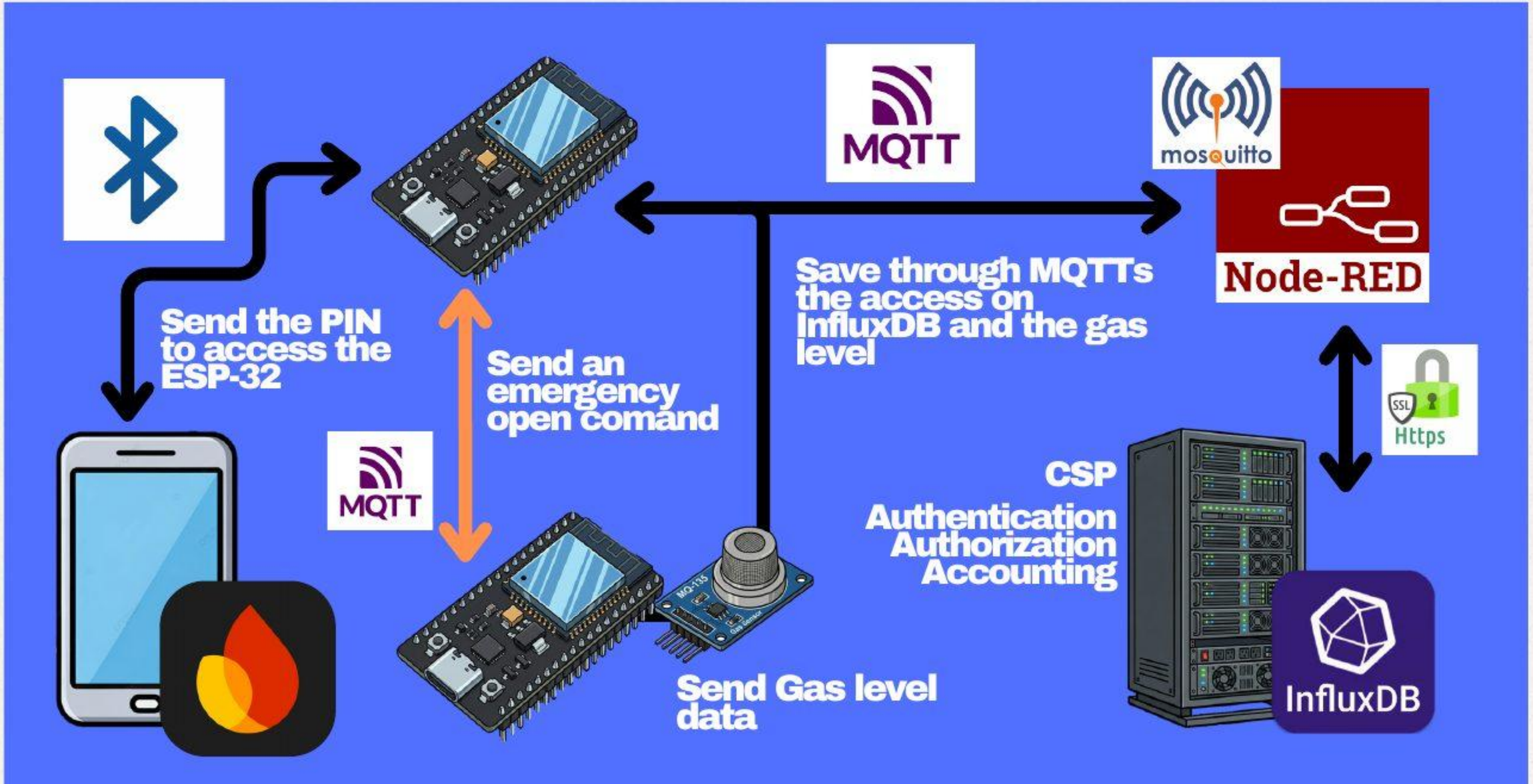
wireshark



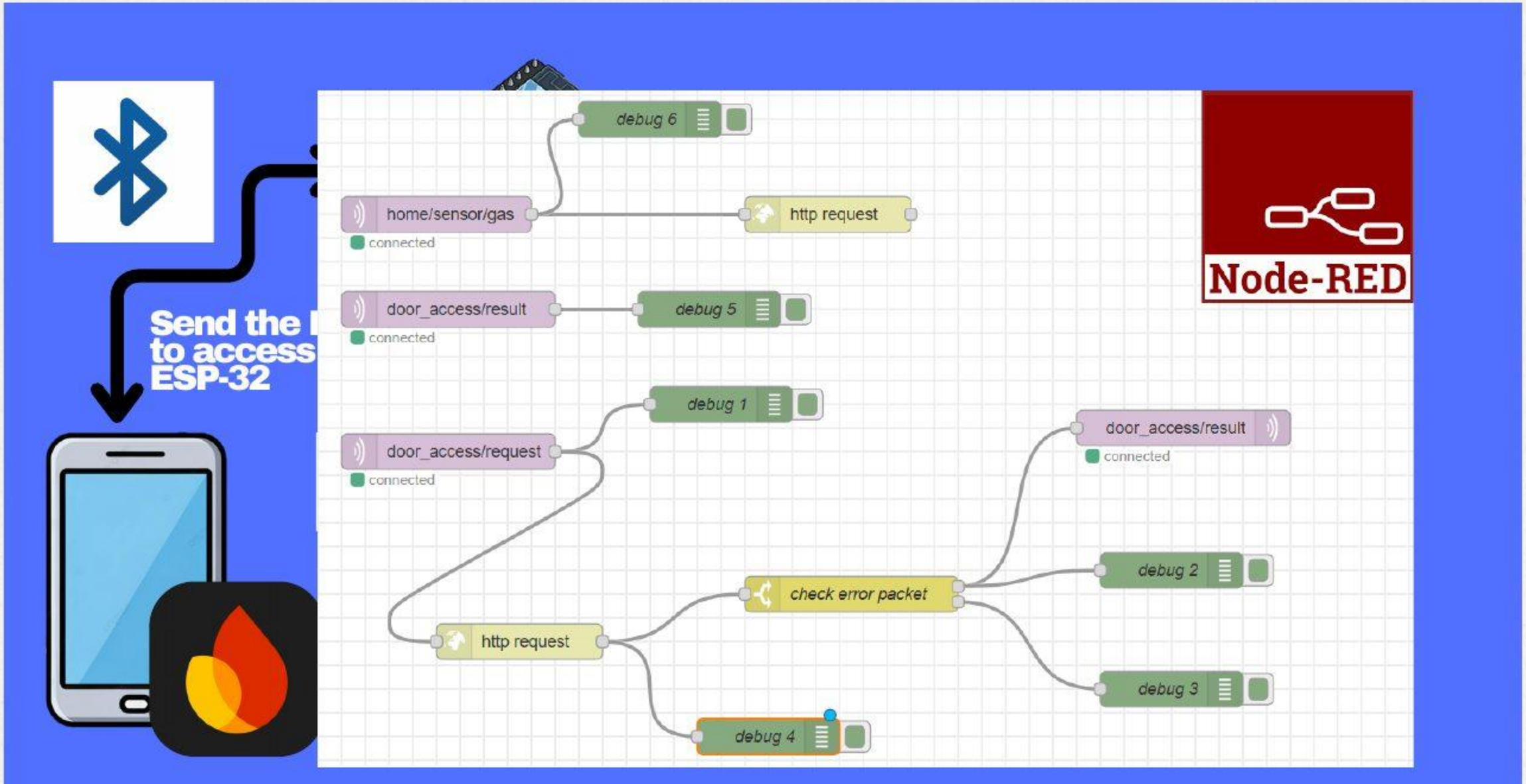


NMAP

Smart Lock IOT Architecture



Smart Lock IOT Architecture



Security Implementation Steps Bluetooth

Plain Text

HMAC

- Integrity

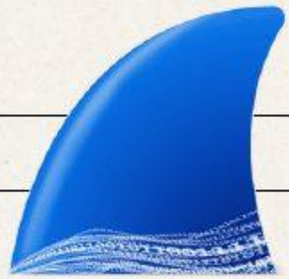
AES

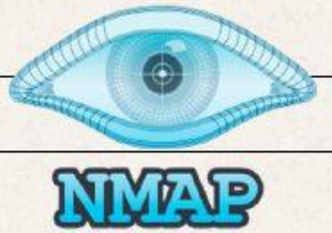
- Integrity
- Authentication
- Confidentiality

MITM

HOW?







Security Implementation Steps MQTT and HTTP

Plain Text

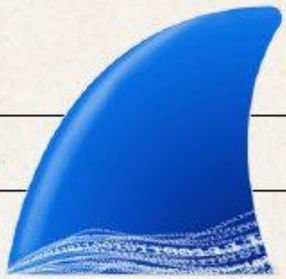
OpenSSL
Cryptography and SSL/TLS Toolkit

TLS
- Integrity
- Authentication
- Confidentiality

MITM

HOW?







System Before Security (Vulnerabilities)

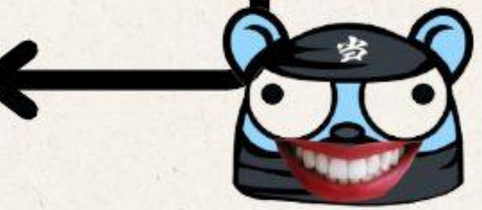
MITM

Attacker connected to the same network

ARP Spoofing used to intercept traffic

Wireshark captured packets successfully

```
10.55.82.0/24 › 10.55.82.136  » set arp.spoof.target 10.55.82.145, 10.55.82.109←[J←[2K
10.55.82.0/24 › 10.55.82.136  » set arp.spoof.internal true←[J←[2K
10.55.82.0/24 › 10.55.82.136  » set arp.spoof,fullduplex true←[J←[2K
10.55.82.0/24 › 10.55.82.136  » set arp.spoof.fullduplex true←[J←[2K
10.55.82.0/24 › 10.55.82.136  » set net.sniff.output.pcap true←[J←[2K
10.55.82.0/24 › 10.55.82.136  » arp.spoof on←[J←[2K
10.55.82.0/24 › 10.55.82.136  » [18:20:24] [sys.log] [war] arp.spoof arp spoofer started ta
neighbours of 256 targets.
10.55.82.0/24 › 10.55.82.136  » [18:20:24] [sys.log] [war] arp.spoof full duplex spoofing e
 spoofing mechanisms, the attack will fail.
```



Capturing from Wi-Fi

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

mqtt

No.	Time	Source	Destination	Protocol	Length	Info
395835	258.177708	10.55.82.145	10.55.82.109	MQTT	56	Ping Request
11096…	286.981619	10.55.82.145	10.55.82.109	MQTT	229	Publish Message [door_access/request]
13493…	297.222959	10.55.82.109	10.55.82.145	MQTT	95	[TCP Spurious Retransmission] , Publish Message [door_access/result]
16664…	311.727387	10.55.82.145	10.55.82.109	MQTT	56	Ping Request

Wireshark · Follow TCP Stream (tcp.stream eq 102) · Wi-

```
0'..door_access/result{"authorized":true}
..
```

Wireshark · Follow TCP Stream (tcp.stream eq 87) · Wi-Fi

```
0....door_access/request{"device_id":"ESP32_GARAGE_01","user_id":"mobile_user_01
"event":"door_access/request","pin":"1234","otp":"123456","timestamp":"1970-01-0
00:00:00Z"}
```

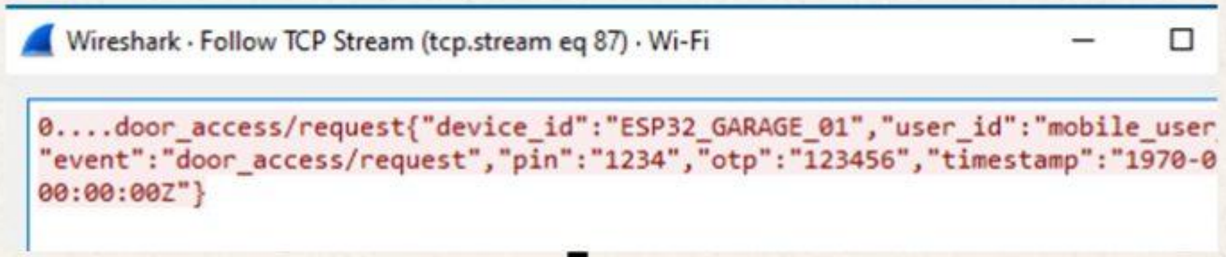
System Before Security (Vulnerabilities)

Replay Attack

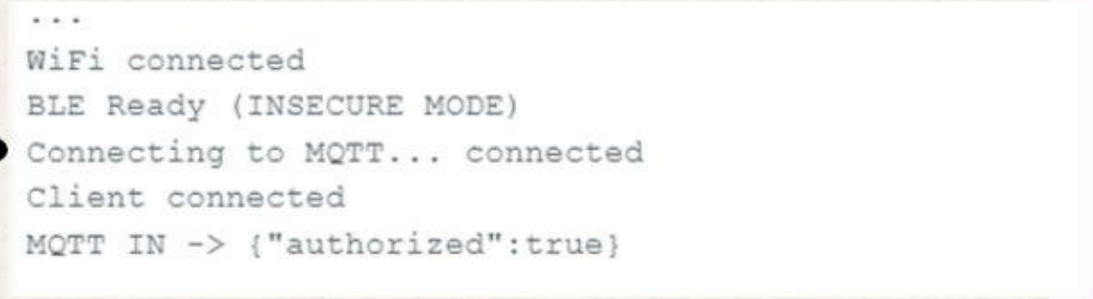
Attacker captured a valid MQTT message

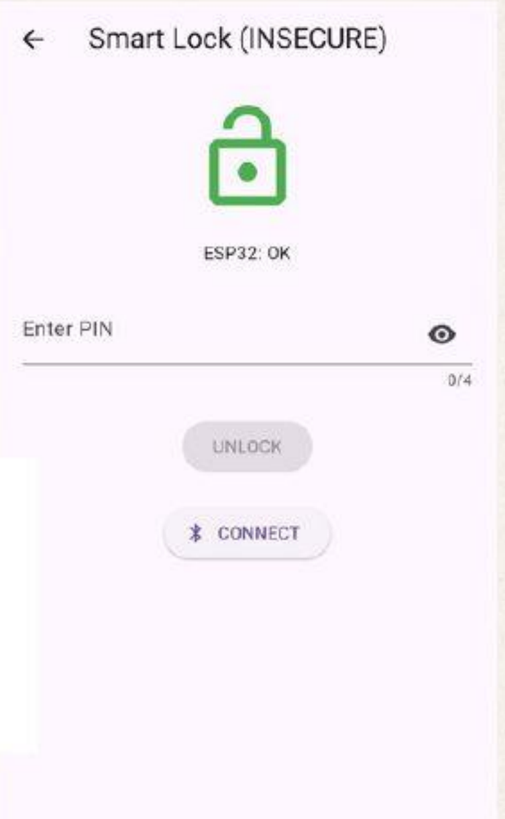
Replayed the same message later

System accepted the message









After Security... Everything it's encrypted



Output Serial Monitor ×

Message (Enter to send message to 'ESP32 Dev Module' on 'COM10')

```
Send MQTTS -> e67155200b983e10400a9b672791ef50c90ea8250d77ed7be055256680a72a1c:MjqwOxYeJVZV9Ov
Send MQTTS -> 7ed0b8fe5f9dd110987b43f8563dd88a88bf8e4ce811b717409604bc990dc0ef:MjqwOxYeJVZV9Ov
Send MQTTS -> 751f1c2f26c8b0fd4152f4d0832bded8b471039cfcf340e4e69435571c3a4643:MjqwOxYeJVZV9Ov

!!! GAS LEAK DETECTED (3 consecutive readings) !!!
Send Emergency -> {"response":"ed02fbf22e1d06618df961cece5bd39c066f93c4165df614727c2ab8cac74b9
Send MQTTS -> 5b6146386ce67184cd16251ed9fd2a78a0b8743da803b284afca31a84d3a847e:MjqwOxYeJVZV9Ov
Send MQTTS -> fdb565e55de244d08158be954a05cb312047e5ca49499b7a17abdffe6c2b97e7:MjqwOxYeJVZV9Ov
```

```
...
WiFi Connected
BLE Started. Name: GARAGE01
Connecting to MQTTS (Secure)... connected
MQTT IN -> ed02fbf22e1d06618df961cece5bd39c066f93c4165df614727c2ab8ca
raeson: home/sensor/gas
```



debug

all nodes | all

2/2/2026, 4:39:52 PM node: debug 6

home/sensor/gas : msg.payload : string[217]

```
"cfa987334a3cc771180cf20f83acac8efcc76aa4d802c1aeaacff41592cef916:MjqwOxYeJVZV9Ov..."
```

2/2/2026, 4:39:54 PM node: debug 6

home/sensor/gas : msg.payload : string[217]

```
"30dd442bd9da7bac790c8cec6175cdeeba1382922f9cbbce3b5025335c89e2c0:MjqwOxYeJVZV9Ov..."
```

2/2/2026, 4:39:56 PM node: debug 5

door_access/result : msg.payload : Object

```
{ response: "ed02fbf22e1d06618df961cece5bd3…"
```

Node-RED

Port scanning

Port & Service Hardening
Insecure port 1883 disabled
Only secure ports exposed
Verified using Nmap

```
Administrator: Command Prompt

C:\Windows\System32>nmap -sV -p 1883,8883,1880,5001 10.48.172.109
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-02 18:55 +0100
PORT     STATE  SERVICE                  VERSION
1880/tcp open   vsat-control?
1883/tcp closed mqtt
5001/tcp open   ssl/commplex-link?
8883/tcp open   ssl/mosquitto version 2.1.0
```

Nmap scan on the ESP32 device
No open TCP ports were detected
The ESP32 operates only as a client, reducing its attack surface

```
C:\Windows\System32>nmap -F 10.48.172.145
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-02 19:03 +0100
Nmap scan report for 10.48.172.145
Host is up (0.075s latency).
All 100 scanned ports on 10.48.172.145 are in ignored states.
Not shown: 100 closed tcp ports (reset)
MAC Address: 68:FE:71:81:6D:CC (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.13 seconds
```

Attack Tests Performed (After Security)

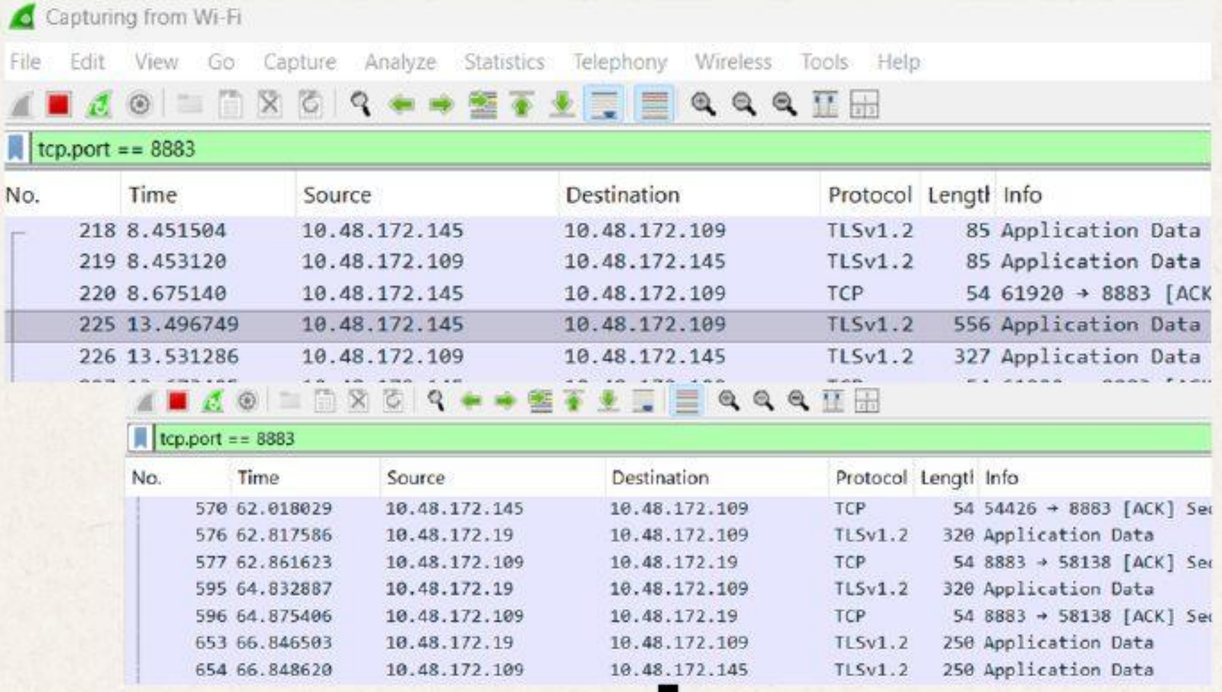
MITM Attack Failure

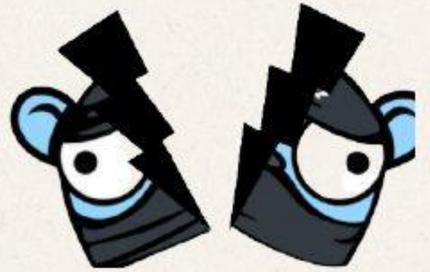
ARP spoofing attempted again

Traffic intercepted but unreadable

Payload fully encrypted



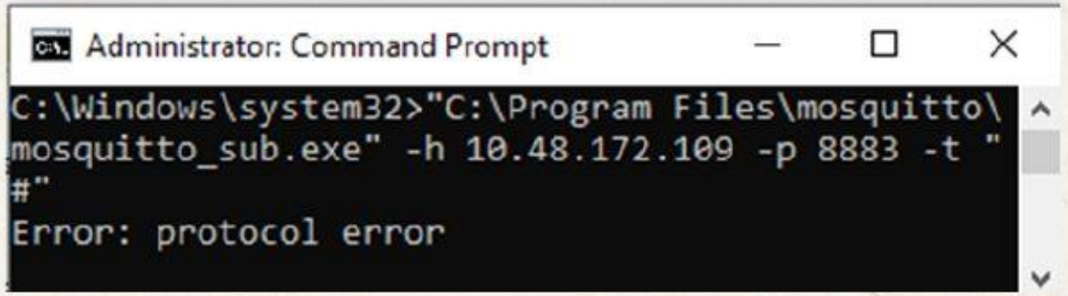




Attack Tests Performed (After Security)

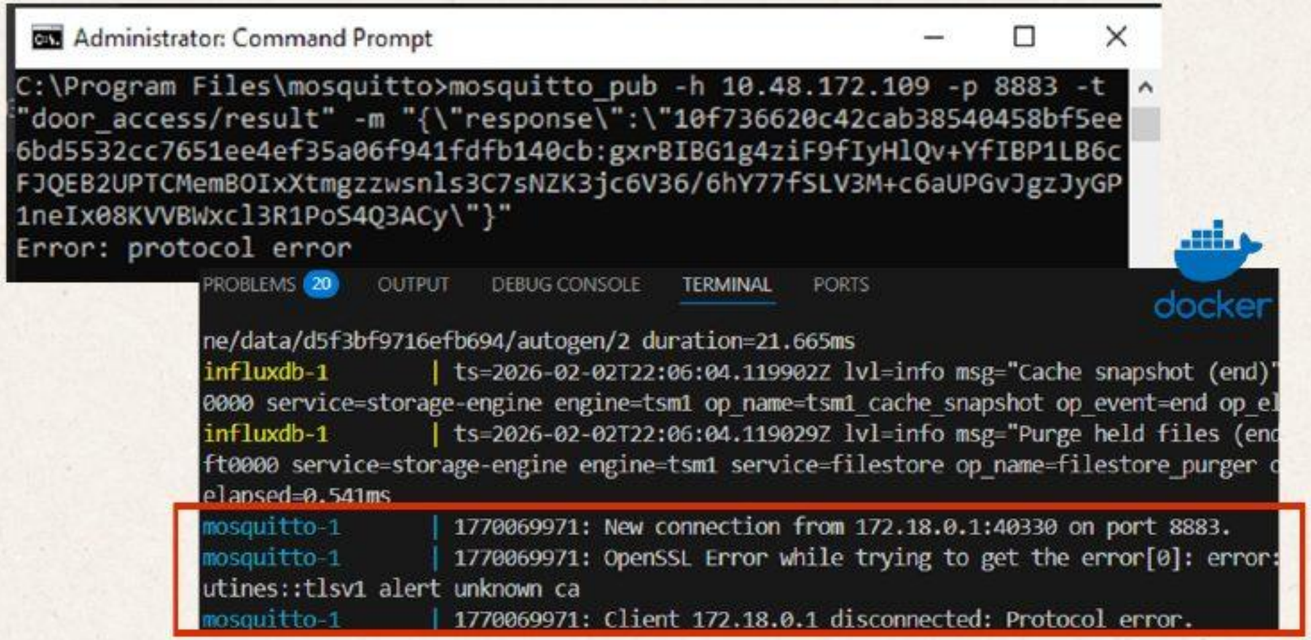
MQTT Attack Attempt

Attacker attempted to connect to the MQTT broker
No valid TLS certificates provided
Connection rejected at protocol level

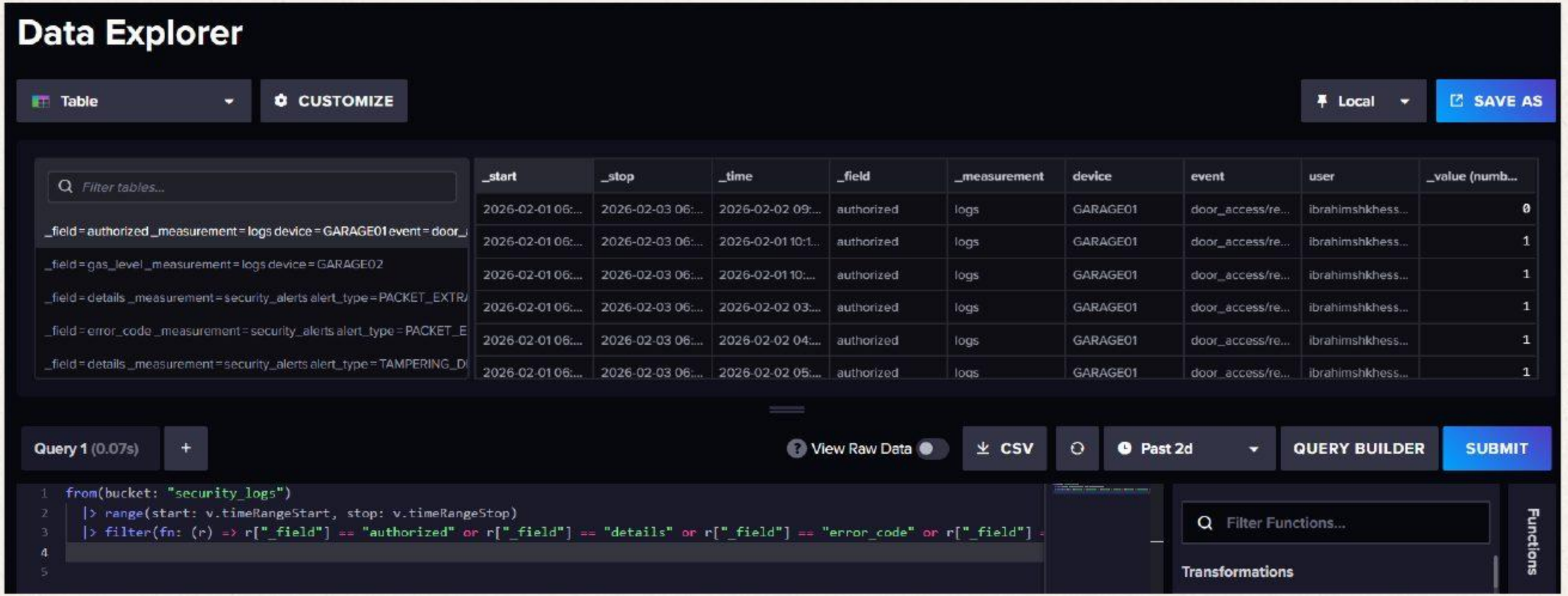


Replay Attack Failure

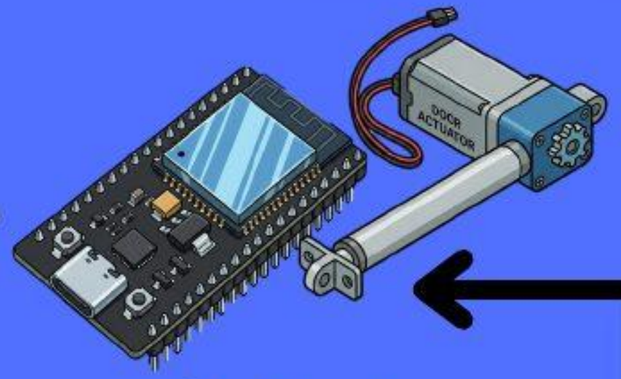
Replayed messages rejected
OTP and nonce validation enforced
Server-side verification blocks attack



System Monitoring & Validation



Future development



MQTT

mosquitto

Node-RED

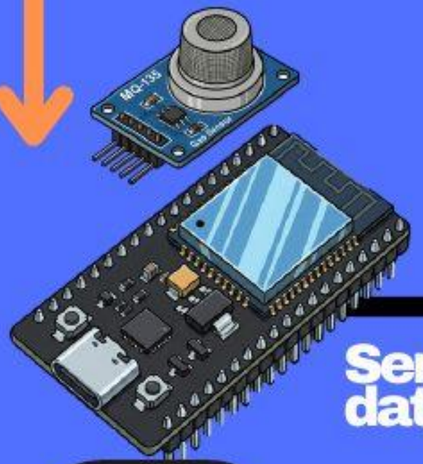
Save through MQTTs the access on InfluxDB

Send the PIN to access the ESP-32

Send an emergency open comand

MQTT





CSP
Authentication
Authorization
Accounting



InfluxDB

Send Gas level data

Request the OTP code

Update the OTP code